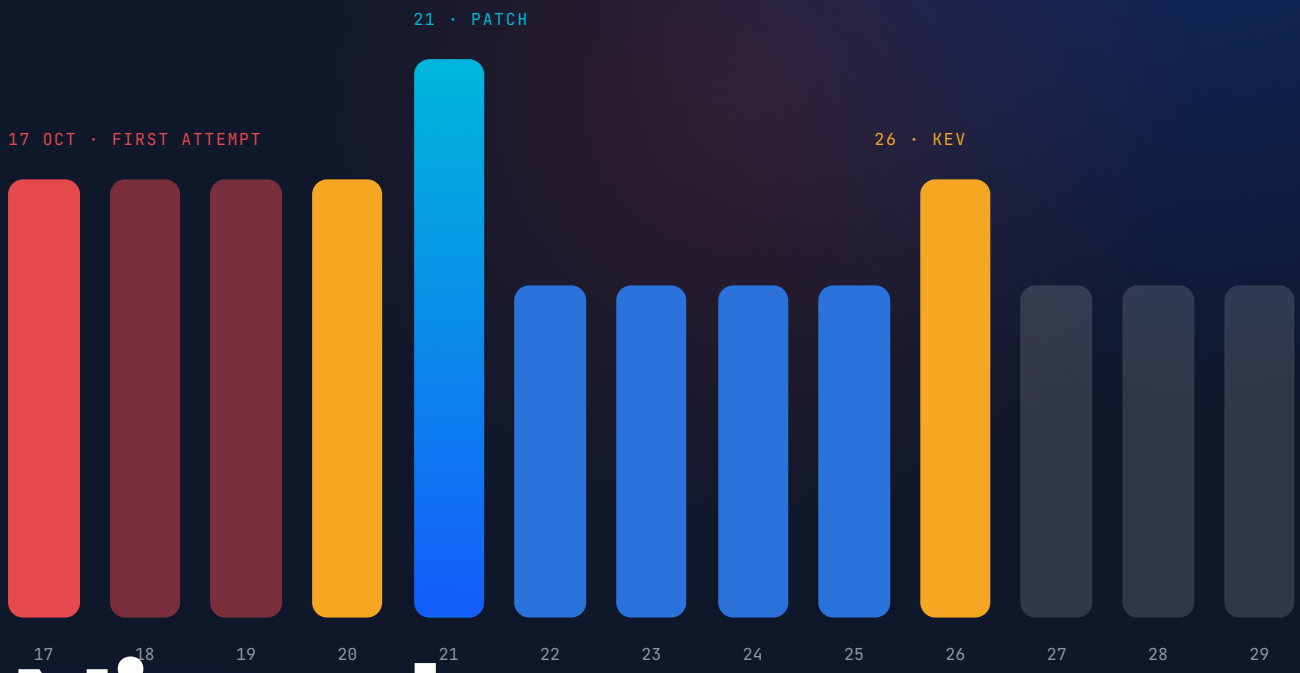
TRANSPUTEC

CASE STUDY · OCT 2026

CVE-2026-109618 · CVE-2026-109619 · CVSS 9.2



Nine days in October.

How two flaws in PHP went from first attack to the CISA exploited list while most of the internet was still deciding whether to patch.

AT A GLANCE

The facts, on one page.

A case study of the fastest-moving PHP security event in years: what the flaws are, how the nine days unfolded, and what it asks of the people who run websites.

Name	PHP2Shell (named by Wiz Research)
CVEs	CVE-2026-109618, CVE-2026-109619
Severity	CVSS v4.0 score 9.2, both
Impact	Unauthenticated remote code execution with the web worker's privileges
Affects	PHP itself: PHP-FPM, Apache mod_php, php-cgi, FrankenPHP, LiteSpeed
Fixed in	PHP 8.5.12, 8.4.27, 8.3.36, 8.2.35 (21 October 2026)
Older branches	Minimal source backports for PHP 7.4 to 8.1; vendor fixes
Exploited	Added to CISA's Known Exploited Vulnerabilities catalogue on 26 October 2026

READ THIS FIRST

This is a live event. Everything here is accurate as of 27 October 2026 and drawn from the sources on page 18. Where sources disagree, we say so. Figures from scans and honeypots describe what researchers saw, not the full picture.

Sources: Rapid7; Tenable; Recorded Future Insikt Group. Full list on page 18.

CONTENTS

Inside.

	Executive summary	04
01	**What broke**	05
	Two bugs, in plain English	06
	Where PHP runs, and what is fixed	07
02	**Nine days in October**	08
	The first hours of 21 October	10
03	**The exposure**	11
04	**Proven, or only claimed?**	12
05	**The response**	13
	What made patching hard	14
06	**The AI question**	15
07	**What to do**	16
	Questions for your IT provider	17
	Sources and method	18

EXECUTIVE SUMMARY

A patch window that closed before it opened.

4d

days between the first recorded exploitation attempt and the public patch[3,4]

11.4h

hours that leaked technical details circulated before the patch shipped[3]

79%

of services showing a PHP version run a branch that no longer gets routine fixes[3]

5.1m

million IP addresses running PHP, counted by VirusTotal[3]

What happened

Two memory-safety flaws in PHP itself, rated 9.2 out of 10, let an unauthenticated attacker run code on a server that handles web requests. They sit beneath WordPress, Drupal, Joomla, Magento and thousands of custom sites. Attacks were recorded four days before the fix. Details leaked hours before it. By 26 October CISA listed both as exploited.[1,3,4]

Banks, retailers, hospitals and some government bodies took services offline to patch, according to TechCrunch.[4]

What it shows

The window between a flaw becoming known and being used is now measured in hours. A patch that exists is not a patch that is installed: running processes keep the vulnerable code until restarted, and most exposed PHP runs on branches with no official fix.[2,3]

Our view: the organisations that coped best were not the best defended. They were the ones that already knew where PHP ran and who owned it.

FOUR ACTIONS

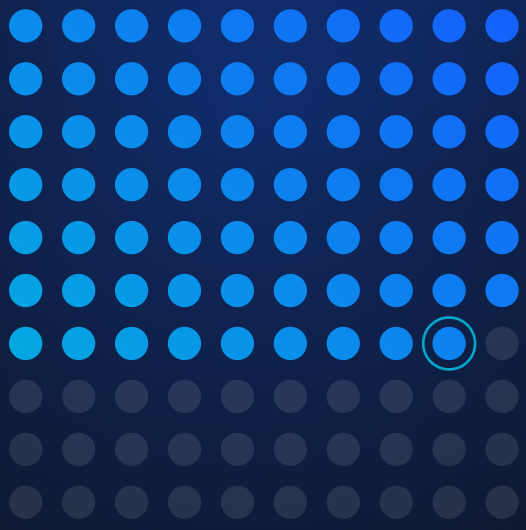
Find every PHP install · Patch and restart, then rebuild images · Look back to 17 October for signs of compromise · Rotate what may have leaked

Sources: 1 Rapid7. 2 Tenable. 3 Recorded Future. 4 TechCrunch. Hours: 02:29 to 13:52 UTC, 21 October.

CHAPTER 01 · WHAT BROKE

69.3%

of websites whose server-side language is known use PHP, according to W3Techs. WordPress, Drupal, Joomla, Laravel and Magento all run on it.[2]



69 OF EVERY 100 SITES

The flaw was not in a website. It was underneath all of them.

01 · WHAT BROKE

Two bugs, in plain English.

Both are memory-safety flaws in how PHP starts, fails and cleans up a request. Neither needs a password or a click.

CVE-2026-109618

The out-of-memory bug

1. An attacker sends a crafted multipart request, the kind used for forms and file uploads.
2. PHP runs out of memory part-way through setting up the request, even when the size looks within limits.
3. PHP abandons the request, leaving internal data half-built.
4. Clean-up runs anyway and uses the invalid data. Memory is corrupted.
5. In Apache mod_php this happens before any of the website's own code runs.

CVE-2026-109619

The stale-state bug

1. A worker process handles many requests in turn, and keeps some state between them.
2. At the end of one request, a pointer still refers to memory that has been freed.
3. A fatal error or timeout interrupts the clean-up that would have reset it.
4. The next request on the same worker reads the stale value, including through session upload progress, which is on by default.
5. Freed memory is reused. Code runs.

WHY IT MATTERS

Because the flaw is in PHP rather than in a plugin, a site can have flawless application code and still be exposed. Wiz also showed that the memory-disclosure side can leak passwords, tokens, API keys and certificates from other requests, with no code execution at all.[3]

Sources: PHP advisories as summarised by Rapid7 and Recorded Future. The session upload progress feature has existed since PHP 5.4.0.

01 · WHAT BROKE

Where PHP runs, and what is fixed.

RUNTIME	EXPOSURE
Apache mod_php	Highest risk. The vendor notes exploitation can succeed before any application code runs.[1]
PHP-FPM	At risk. A worker ends on failed start-up, which blocks one sequence, but a session path was validated.[1]
php-cgi	At risk.[1]
FrankenPHP	At risk.[1]
LiteSpeed	At risk.[1]

FIXED RELEASES · 21 OCTOBER 2026

PHP 8.5	PHP 8.4	PHP 8.3	PHP 8.2
8.5.12	8.4.27	8.3.36	8.2.35

PHP 7.4, 8.0 and 8.1 get no official release. The PHP security team published minimal source backports; distributions and long-term-support vendors issued their own.[1,2] An update that contains both fixes is the only complete remediation.[1]

EXPLOITS DEMONSTRATED AGAINST

WORDPRESS · DRUPAL · JOOMLA · MAGENTO · MEDIAWIKI · SYMFONY · LARAVEL · PHPBB

Wiz and Calif demonstrated WordPress, Drupal, Joomla and Magento; Trail of Bits showed shells on MediaWiki, Symfony, Laravel and phpBB, all on unpatched PHP.[3,4]

Sources: 1 Rapid7. 2 Tenable. 3 Recorded Future. 4 TechCrunch; Tenable FAQ.

02 · NINE DAYS IN OCTOBER

Before the world knew.

19 AUG

Discovery

Wiz Research finds the first flaw using AI-assisted tools. Within two days it confirms unauthenticated code execution on Drupal, then WordPress.[3]

24 AUG

Reported to PHP

Wiz privately reports the flaws to the PHP security team, starting coordinated disclosure. Calif and OpenAI are credited alongside Wiz.[3]

21 SEP

Fixes begin

The PHP security team acknowledges the reports and starts building coordinated fixes. Large hosts and Linux distributions later receive early access under embargo.[3,4]

17 OCT

First recorded attack

Amazon's MadPot honeypots log an exploitation attempt, four days before public disclosure. It is unclear how the attacker knew.[2]

20 OCT

A warning, without details

PHP announces an out-of-band release for 21 October at 14:00 UTC and withholds technical detail. watchTowr says it has reproduced CVE-2026-109618.[3]

SOURCES DIFFER

Recorded Future dates the discovery to August 2026. TechCrunch reports the bugs were first noticed in 2024 and judged unexploitable until recently. We follow the dated timeline; the difference does not change what to do.

Sources: 2 Amazon Threat Intelligence, as reported by Tenable. 3 Recorded Future Insikt Group. 4 TechCrunch.

02 · NINE DAYS IN OCTOBER

The week it happened.

21 OCT · 02:29 UTC

Details leak

An archive containing leaked vulnerability information is first submitted to VirusTotal.[3]

21 OCT · 07:34 UTC

Hosts report attacks

Patchstack receives reports of multiple active exploitation incidents from hosting partners, hours ahead of the planned release.[3]

21 OCT · 13:52 UTC

Patch ships, eight minutes early

PHP releases 8.5.12, 8.4.27, 8.3.36 and 8.2.35. Cloudflare reports early attacks and switches on stopgap firewall rules for all customers, including free.[2,3]

23 OCT

A third issue

The PHP Foundation publishes CVE-2026-115560. No patch yet; setting session.upload_progress.enabled=0 is the interim mitigation.[1]

24 OCT

Exploitation confirmed on honeypots

Researcher Adel Karimi reports successful attacks on three honeypots running PHP 8.4.26. The requests started shells that ran attacker commands.[2]

26 OCT

Working exploits, then the KEV list

Trail of Bits confirms working exploits against pre-patch PHP 8.2 to 8.5. CISA adds both CVEs to its Known Exploited Vulnerabilities catalogue; federal agencies must remediate by 29 October.[1,2]

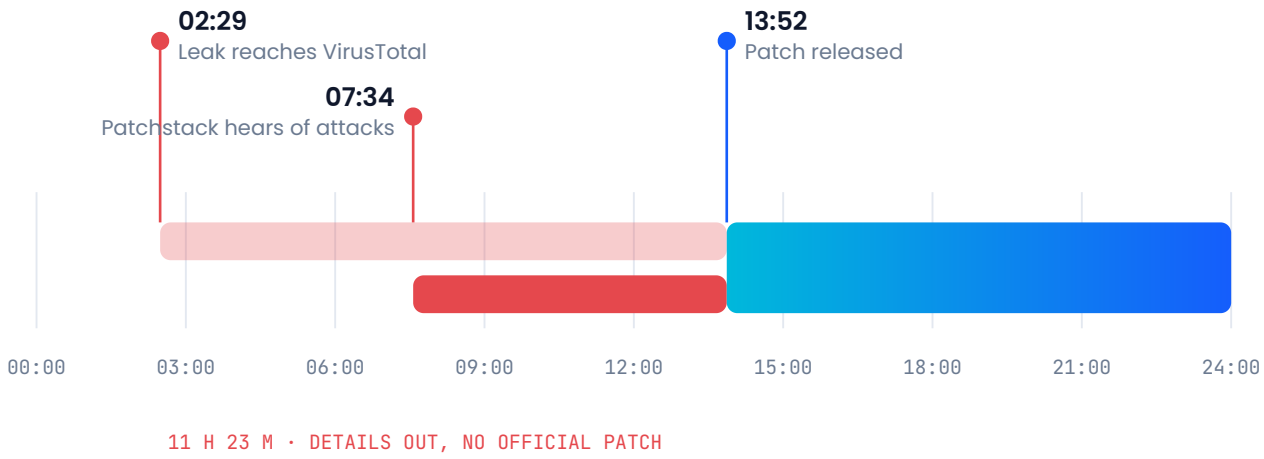
Sources: 1 Rapid7 (update of 27 October). 2 Tenable. 3 Recorded Future Insikt Group. Times UTC.

02

02 · NINE DAYS IN OCTOBER

The first hours of 21 October.

Coordinated disclosure assumes a quiet gap between the patch and the exploit. That gap lasted about eleven hours, and for some it never existed.



−4 days

Amazon saw an attempt on 17 October. How the attacker knew remains unexplained.[2]

6 h 18 m

between Patchstack's first reports from hosting partners and the patch.[3]

8 min

The release went out ahead of its 14:00 UTC schedule. The PHP Foundation blamed one company for publishing early.[3,4]

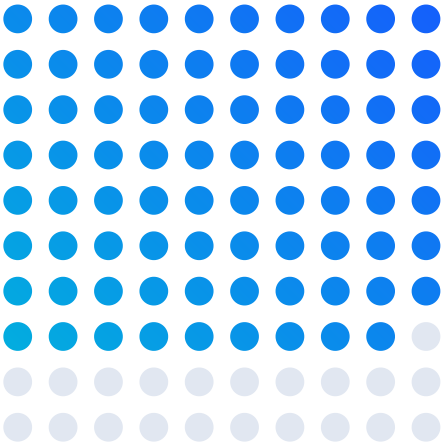
OUR VIEW

Embargoes protect the many by trusting the few, and open-source patches show attackers where to look. Plan as though the gap does not exist: a critical fix should be installed in hours, not at the next maintenance window.

Sources: 2 Tenable (Amazon Threat Intelligence). 3 Recorded Future. 4 TechCrunch. All times UTC.

03 · THE EXPOSURE

Most of the exposed PHP cannot be patched upstream.



79 OF 100 SERVICES WITH A READABLE VERSION

79%

of PHP services that report a version run a branch PHP no longer supports. PHP 7.4, end of life since 2022, accounts for 878,761 services, more than any supported branch.[3]

Modat: 4,384,302 PHP services on 1,886,612 hosts, seen in the ten days before 20 October.

5.1m

IP addresses running PHP (VirusTotal, 21 October). About four in five hide their version.[3]

758k

of those that disclose a version run an end-of-life branch, against about 272,000 on a supported one.[3]

85k

were on the 24 September releases, the newest before the fix. Being current was no protection.[3]

OTHER DOORS OPEN ON THE SAME HOSTS



PHP hosts that also expose these services, per VirusTotal. A foothold on the web server does not have to end there.[3]

Source: 3 Recorded Future Insikt Group, citing Modat and VirusTotal scans. Neither scan counts confirmed vulnerable hosts.

04 · PROVEN, OR ONLY CLAIMED?

Five rungs of evidence.

Early headlines said everything from “nothing seen” to “the internet is on fire”. Both were true at different rungs. Here is how to read the claims.

Catalogued

Rapid7, Tenable

CISA adds both CVEs to KEV on 26 October, evidence of active exploitation. Federal deadline 29 October.

Observed succeeding

Tenable

Shells ran attacker commands on three honeypots (PHP 8.4.26). Trail of Bits shows working exploits on MediaWiki, Symfony, Laravel and phpBB.

Reproduced in the lab

Recorded Future

watchTowr reproduced both. Wiz demonstrated code execution on WordPress, Drupal and Joomla.

Attempted

Tenable, TechCrunch

Amazon (17 Oct), Patchstack's hosts and Cloudflare (21 Oct) saw attacks. Cloudflare later reported an exponential rise in attempts.

Warned

Recorded Future

PHP announces an emergency release on 20 October with details withheld.

CAUTION

Rapid7 found the early public proofs of concept worked only in narrow lab conditions and treated the difficulty as *a window to patch rather than a reason to delay*. Days later, working exploits were confirmed. Reliable exploitation is a matter of time.[1]

Sources: 1 Rapid7. 2 Tenable. 3 Recorded Future. 4 TechCrunch.

05 · THE RESPONSE

Who did what.

Most of the system worked. The weak points were hours, restarts and the long tail of systems nobody was watching.

MAINTAINERS

The PHP Foundation ran a coordinated disclosure, giving large hosts and Linux distributions early access under embargo, then published fixes on 21 October.[4]

PLATFORMS

Cloudflare put stopgap firewall rules in front of PHP sites for every customer, free tier included, and said plainly that they were only a stopgap.[3]

GOVERNMENTS

CISA listed both CVEs as exploited, set 29 October as the federal deadline and required forensic triage. CERT-EU advised isolating internet-facing PHP apps that cannot be updated. The UK NCSC reportedly advised updating or taking systems offline, per BleepingComputer.[1,2,6]

BUSINESSES

Banks, retailers, gaming sites, online stores, hospitals and some government agencies took servers offline to apply patches, TechCrunch reported.[4]

OUR VIEW

Taking a site offline is a legitimate control, not a failure. The organisations that could make that call in an hour had already decided who is allowed to make it, and what a day without the site costs.

Sources: 1 Rapid7. 2 Tenable (CERT-EU). 3 Recorded Future; Tenable. 4 TechCrunch. 6 BleepingComputer, for the UK NCSC advice; we could not retrieve the NCSC's own text.

05

05 · THE RESPONSE

Six traps that made patching hard.

01

Updated is not patched

Installing a new package does not fix processes already running. PHP-FPM and Apache keep the vulnerable code in memory until restarted. Google Cloud's guidance, with Mandiant, also advises capturing worker memory from probed servers before restarting.[2]

02

Containers keep the old image

Patching a running container leaves the image exposed. Rebuild and redeploy.[7]

03

End of life, no fix

PHP 8.1 and older get minimal source backports only. Remi's repository did not update on 21 October; users were told to switch to distribution packages or build from source.[1]

04

A regression in the fix

PHP 8.4.27 and 8.5.12 can crash some applications that use SimpleXML (php-src issue 24488). It comes from a separate garbage-collector change, not the security patches.[2]

05

More after the patch

CVE-2026-115560 had no patch on 23 October. On Windows, builds were refreshed on 26 October for a bundled Brotli flaw, CVE-2026-111497.[1,2]

06

PHP you did not install

PHP also sits in developer tools and in components used by routers, storage devices, firewalls and VPNs. Those need their vendors to ship updates.[4]

Sources: 1 Rapid7. 2 Tenable. 4 TechCrunch. 7 Aikido.

CHAPTER 06 · THE AI QUESTION

Found with help from AI. Not found by it alone.

WHAT WAS REPORTED

Wiz and Calif both say they used AI models in the research. Calif's write-up is blunt about the limits: ***"No model is simply capable of unearthing 'all bugs' with simple prompts. At least for now."*** The bulk of the work relied on researchers who knew PHP's code and exploitation history well.[3,4]

Calif's audit was part of OpenAI's Patch the Planet programme; TechCrunch calls it Hack the Planet. Calif dates its own audit to 30 July and its first report to PHP to 11 August, earlier than Wiz's 19 and 24 August, so two teams appear to have found overlapping bugs independently.[3,4]

WHY IT CHANGES PLANNING

Old, widely used, memory-unsafe software is the likeliest place for the next discovery. TechCrunch cites the NSA's estimate that around 75% of actively exploited vulnerabilities abuse memory-related flaws.[4]

If finding flaws gets cheaper for defenders, it gets cheaper for everyone. The honest planning assumption is shorter windows, not longer ones.

NOT THE FIRST PHP WARNING

Before PHP2Shell, CISA's catalogue already held three PHP flaws. CVE-2024-4577 (PHP-CGI) and CVE-2019-11043 (PHP-FPM) are both known to have been used in ransomware campaigns. The third, CVE-2012-1823, is the flaw CVE-2024-4577 later bypassed.[2]

Sources: 2 Tenable. 3 Recorded Future. 4 TechCrunch.

07 · WHAT TO DO

A 72-hour runbook.

Illustrative, built from the vendor, CISA and researcher guidance in the sources. Adapt it to your estate.

FIRST HOUR
Decide

- Name an incident owner and a decision-maker for taking sites offline.
- Pull the asset list: every web server, container image and appliance that runs PHP.
- Rank by internet exposure; mod_php first.

HOURS 1–24
Contain

- Apply vendor packages or the fixed versions. Restart every PHP process. Rebuild images.
- Where you cannot patch: isolate, or take offline. Treat a web firewall as a stopgap.
- Apply PHP's interim settings where they fit, and check nothing restores a finite memory limit.

HOURS 24–72
Hunt

- Look back to 17 October in web, application and endpoint logs.
- Watch for odd multipart requests, PHP worker crashes and unexpected commands.
- Absence of log entries is not proof of safety.

DAYS 3–30
Recover

- Rotate secrets and keys that a PHP worker could reach.
- Move end-of-life branches onto supported releases.
- Write down what slowed you, and fix it.

Sources: Rapid7; Tenable; Recorded Future recommendations. This runbook is illustrative and is not a substitute for a vendor advisory.

07 · WHAT TO DO

Six questions for your IT provider, today.

A good answer is specific, quick and written down. A vague one is also an answer.

01 "Do we know every place PHP runs, including inside appliances and containers? Show me the list."

02 "How many of our PHP installs are on a branch with no official fixes?"

03 "How quickly can we patch and restart a critical, internet-facing system? Has it been tested?"

04 "Who can decide to take a site offline, and what does an hour of that cost?"

05 "Which secrets could a compromised PHP worker reach, and how fast can we rotate them?"

06 "Who tells us about a supplier's incident, and how quickly, in writing?"

PLAYBOOK

These questions map onto plays 01, 03 and 05 of The Resilience Playbook: map what matters, rehearse recovery, know your suppliers.

SOURCES AND METHOD

Where this comes from.

1 Rapid7. **CVE-2026-109618 and CVE-2026-109619: Critical Unauthenticated Remote Code Execution in PHP.** 21 October 2026, updated 27 October. rapid7.com/blog/post/etr-cve-2026-109618-and-cve-2026-109619-critical-unauthenticated-remote-code-execution-in-php/

2 Tenable. **PHP2Shell: frequently asked questions about critical PHP remote code execution.** Updated 26 October 2026. tenable.com/blog/php2shell-cve-2026-109618-cve-2026-109619-frequently-asked-questions-about-critical-php-remote

3 Recorded Future Insikt Group. **PHP2Shell Exploitation: Two Critical PHP Flaws Explained.** recordedfuture.com/blog/php2shell-vulnerability-exploitation

4 TechCrunch (Z. Whittaker). **PHP-ocalypse: How two critical web bugs almost broke the internet.** 24 October 2026. techcrunch.com/2026/10/24/php-ocalypse-how-two-critical-web-bugs-almost-broke-the-internet/

5 CISA. **Critical Vulnerabilities in PHP Require Immediate Patching.** 21 October 2026. cisa.gov/news-events/alerts/2026/10/21/critical-vulnerabilities-php-require-immediate-patching (not retrievable by us; the KEV listing is taken from sources 1 and 2).

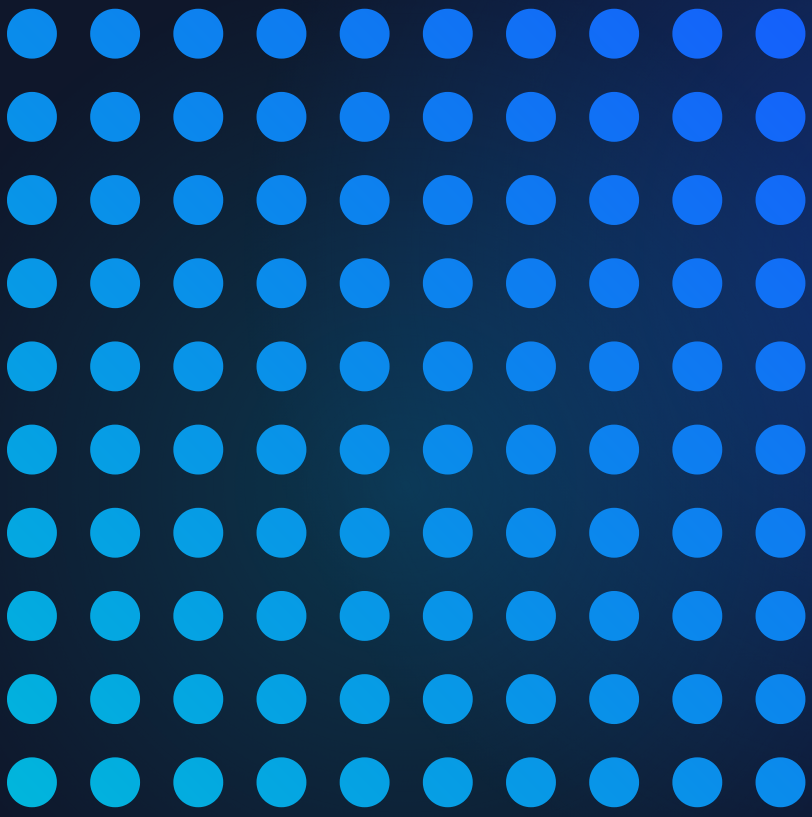
6 BleepingComputer, as summarised in search results, for the UK NCSC advice. We did not retrieve the NCSC's own text.

7 Aikido. **Critical vulnerabilities in PHP (PHP2Shell): how to fix.** aikido.dev/blog/critical-vulnerabilities-in-php-php2shell

METHOD NOTES

Accurate as of 27 October 2026; the event is still moving. Exposure counts come from scans that count differently, so they are not comparable. Exploitation reports from vendors describe what they observed, not total compromise. Fixes and regressions may have changed since publication; check the PHP project's advisories.

Sources 5 and 6 are listed for completeness. Nothing in this study rests on text we could not read.



TRANSPUTEC

Fixed-fee managed IT with 24/7 support,
patching and incident response under SLA.

LRQA CERTIFIED · LRQA CERTIFIED ISO 14001 · CYBER ESSENTIALS CERTIFIED PLUS · OFFENSIVE SECURITY OSCP

Microsoft Solutions Partner — Modern Work

Microsoft Solutions Partner — Security

aws PARTNER Advanced Tier Services

CISCO Partner